

INFORME DE PENTESTING

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe (Basic Pentesting)

Seguridad Aplicada a Sistemas de Información — FID-UCH

1. Datos generales

Cliente	INSECUR S.A.
Contratista (alumno/a)	Martin Vera
DNI	43484838
Username TryHackMe	veram321422
Email institucional	veramartinandres@uch.ar
Sala de elección (Nivel 2)	Basic Pentesting (tryhackme.com/room/basicpentestingit)
Branch en GitHub	vera-martin
Fecha de inicio	07/10/2026
Fecha de cierre	08/10/2026

2. Pre-pentesting

2.1 Alcance del trabajo

[ANTES] Completar antes de tocar la VPN.

Dentro del alcance: exclusivamente la máquina objetivo asignada por TryHackMe en la sala Basic Pentesting (IP 10.65.148.83, dinámica por instancia). Fuera de alcance: cualquier otro sistema, incluyendo infraestructura de TryHackMe, de la facultad o de terceros.

2.2 Reglas de Enfrentamiento (ROE)

[ANTES] Restricciones técnicas acordadas.

Pruebas realizadas únicamente a través de la VPN oficial de TryHackMe. Sin ataques de denegación de servicio. Tráfico limitado al necesario para enumeración y explotación de la máquina asignada. Cualquier incidente se documenta en la bitácora.

2.3 Autorización

[ANTES] Declaración de autorización.

Se cuenta con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para operar sobre los entornos de laboratorio de TryHackMe indicados en la Guía + Plantilla A08.

2.4 Metodología utilizada

[ANTES] Marco seguido y justificación.

Se siguió el flujo profesional de pentesting indicado en la guía de cátedra (Preengagement → Reconocimiento → Escaneo → Enumeración → Explotación → Postexplotación → Reporte), alineado conceptualmente con PTES (Penetration Testing Execution Standard).

3. Durante: Hallazgos por fase

[DURANTE] Hallazgos documentados a medida que se avanzó por cada fase.

Hallazgo H-01

ID del hallazgo	H-01
Fase	☒ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Puerto 22/TCP abierto, servicio SSH (OpenSSH 8.2p1 Ubuntu 4ubuntu0.13).
Componente afectado	Servicio SSH
Categoría (OWASP / CWE)	CWE-200 Exposure of Information
CVE (si aplica)	N/A
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/nmap_inicial.txt
Herramienta utilizada	Nmap (-sC -sV)
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir acceso SSH por IP/VPN; mantener versión actualizada.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-02

ID del hallazgo	H-02
Fase	☒ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Puerto 80/TCP abierto, Apache httpd 2.4.41 (Ubuntu), sin título visible en el sitio.
Componente afectado	Servidor web Apache
Categoría (OWASP / CWE)	CWE-200 Exposure of Information
CVE (si aplica)	N/A
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/nmap_inicial.txt
Herramienta utilizada	Nmap (-sC -sV)
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Actualizar Apache (versión actual recomendada $\geq 2.4.68$) y ocultar banner de versión.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-03

ID del hallazgo	H-03
Fase	☒ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Postexplotación

Descripción	Puertos 139/445 TCP abiertos, servicio Samba smbd 4 (4.15.13-Ubuntu), message signing habilitado pero no requerido.
Componente afectado	Servicio Samba/SMB
Categoría (OWASP / CWE)	CWE-200 Exposure of Information
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/nmap_inicial.txt
Herramienta utilizada	Nmap (-sC -sV)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Forzar SMB signing obligatorio; restringir exposición de 139/445 a red interna.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-04

ID del hallazgo	H-04
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Enumeración de usuarios del sistema vía sesión nula SMB (RID cycling): kay, jan, ubuntu.
Componente afectado	Servicio Samba/SMB
Categoría (OWASP / CWE)	CWE-287 Improper Authentication
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/enum4linux.txt
Herramienta utilizada	enum4linux -a
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Deshabilitar sesiones nulas (null sessions) en la configuración de Samba.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-05

ID del hallazgo	H-05
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Share SMB "Anonymous" accesible sin autenticación, con listado de contenido habilitado (Mapping: OK, Listing: OK).
Componente afectado	Share SMB "Anonymous"
Categoría (OWASP / CWE)	CWE-284 Improper Access Control
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/enum4linux.txt; smbclient
Herramienta utilizada	enum4linux, smbclient
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Eliminar o restringir el share anónimo; exigir autenticación para cualquier recurso compartido.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-06

ID del hallazgo	H-06
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Política de contraseñas débil detectada: longitud mínima 5 caracteres, complejidad deshabilitada.
Componente afectado	Política de dominio/workgroup BASIC2
Categoría (OWASP / CWE)	CWE-521 Weak Password Requirements

CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/enum4linux.txt
Herramienta utilizada	enum4linux -a
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Exigir longitud mínima 12+ caracteres y complejidad obligatoria (mayúsculas, números, símbolos).
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-07

ID del hallazgo	H-07
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Archivo staff.txt obtenido del share anónimo confirma nombres de usuarios reales del staff: Kay y Jan.
Componente afectado	Share SMB "Anonymous"
Categoría (OWASP / CWE)	CWE-200 Exposure of Information
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	staff.txt (descargado); evidencias/escaneo/
Herramienta utilizada	smbclient
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	No publicar información interna (nombres, roles) en recursos compartidos accesibles anónimamente.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-08

ID del hallazgo	H-08
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Postexplotación
Descripción	Credencial SSH válida obtenida por fuerza bruta de diccionario: usuario jan, contraseña "armando".
Componente afectado	Servicio SSH — usuario jan
Categoría (OWASP / CWE)	CWE-521 Weak Password Requirements
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/hydra_rapido.txt
Herramienta utilizada	Hydra (-L users.txt -P wordlist)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Política de contraseñas robusta + bloqueo de cuenta tras intentos fallidos + MFA en SSH.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-09

ID del hallazgo	H-09
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Postexplotación
Descripción	Acceso shell confirmado como usuario jan (uid 1001) vía SSH. Sin privilegios de sudo para este usuario.
Componente afectado	Sistema operativo — cuenta jan
Categoría (OWASP / CWE)	T1078 Valid Accounts (MITRE ATT&CK)

CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	Sesión SSH interactiva
Herramienta utilizada	ssh
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Ver H-08 (origen de la credencial). Aplicar principio de menor privilegio.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-10

ID del hallazgo	H-10
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Directorio /development/ expuesto en el servidor web con listado de directorio (directory indexing) habilitado.
Componente afectado	Servidor web Apache — /development/
Categoría (OWASP / CWE)	CWE-548 Exposure of Information Through Directory Listing
CVE (si aplica)	N/A
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	bitacora/nikto.txt
Herramienta utilizada	Nikto
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Deshabilitar directory indexing (Options -Indexes en Apache) y remover contenido de desarrollo de producción.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-11

ID del hallazgo	H-11
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Postexplotación
Descripción	Notas de desarrollo expuestas en /development/ revelan uso previo de Apache Struts 2.5.12 con el ejemplo REST. Verificado que el componente no está actualmente desplegado (404 en rutas estándar /struts2-rest-showcase/).
Componente afectado	Notas de desarrollo (/development/)
Categoría (OWASP / CWE)	CWE-200 Exposure of Information
CVE (si aplica)	CVE-2017-9805 (no confirmado explotable en este objetivo)
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/escaneo/; curl /development/
Herramienta utilizada	curl, searchsploit
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	No dejar notas internas ni información de stack tecnológico accesibles públicamente.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-12

ID del hallazgo	H-12
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Postexplotación

Descripción	Clave privada SSH del usuario kay (id_rsa) con permisos de lectura para otros usuarios del sistema (-rw-r--r--), permitiendo que jan la copiara.
Componente afectado	Archivo /home/kay/.ssh/id_rsa
Categoría (OWASP / CWE)	CWE-732 Incorrect Permission Assignment for Critical Resource
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	ls -la /home/kay/.ssh (sesión SSH como jan)
Herramienta utilizada	Shell SSH
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir permisos de claves privadas a 600 (solo lectura/escritura del propietario).
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-13

ID del hallazgo	H-13
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Postexplotación
Descripción	Passphrase de la clave privada de kay crackeada offline mediante diccionario (rockyou.txt): "beeswax".
Componente afectado	Clave privada SSH de kay
Categoría (OWASP / CWE)	CWE-521 Weak Password Requirements
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	kay_hash.txt; salida de John the Ripper
Herramienta utilizada	ssh2john + John the Ripper
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Usar passphrases robustas y únicas para claves privadas; rotarlas periódicamente.
Riesgo residual tras aplicar	☐ Bajo ☒ Medio ☐ Alto

Hallazgo H-14

ID del hallazgo	H-14
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Postexplotación
Descripción	Archivo pass.bak en el home de kay contiene la contraseña de sudo en texto plano.
Componente afectado	Archivo /home/kay/pass.bak
Categoría (OWASP / CWE)	CWE-312 Cleartext Storage of Sensitive Information
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	cat /home/kay/pass.bak (sesión SSH como kay)
Herramienta utilizada	Shell SSH
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Nunca almacenar contraseñas en texto plano; usar gestores de secretos.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Hallazgo H-15

ID del hallazgo	H-15
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Postexplotación
Descripción	Escalada de privilegios exitosa a root mediante sudo, usando la credencial obtenida en H-14. El usuario kay pertenece al grupo sudo con permisos (ALL:ALL) ALL.
Componente afectado	Sistema operativo completo

Categoría (OWASP / CWE)	T1548 Abuse Elevation Control Mechanism (MITRE ATT&CK)
CVE (si aplica)	N/A
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	sudo su - ; id (uid=0 root)
Herramienta utilizada	sudo
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Revisar membresía del grupo sudo; aplicar principio de menor privilegio; auditar uso de sudo.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

4. Resumen ejecutivo de hallazgos

[DESPUÉS] *Conteo final por severidad.*

Severidad	Cantidad	ID de hallazgos
Crítico	3	H-12, H-14, H-15
Alto	5	H-05, H-07, H-08, H-09, H-13
Medio	3	H-03, H-04, H-06
Bajo	5	H-01, H-02, H-10, H-11
Total	15	H-01 a H-15

5. Post-pentesting: Recomendaciones

5.1 Recomendaciones técnicas (parches y configuraciones)

1) Eliminar inmediatamente `/home/kay/pass.bak` y rotar todas las credenciales asociadas (H-14, H-15). 2) Corregir permisos de `id_rsa` a 600 en todas las cuentas (H-12). 3) Deshabilitar acceso anónimo y sesiones nulas en Samba (H-04, H-05, H-07). 4) Forzar política de contraseñas robusta: mínimo 12 caracteres, complejidad obligatoria (H-06, H-08, H-13). 5) Deshabilitar `directory indexing` en Apache y remover `/development/` de producción (H-10, H-11). 6) Revisar y limitar membresía del grupo `sudo` al mínimo necesario (H-15). 7) Actualizar Apache a versión soportada (H-02).

5.2 Recomendaciones administrativas (políticas y procesos)

Implementar revisiones periódicas de permisos de archivos sensibles. Capacitar al personal sobre almacenamiento seguro de credenciales (no en archivos de texto plano). Establecer un proceso de `hardening` previo al pase a producción que incluya checklist de servicios expuestos. Auditorías trimestrales de cuentas con privilegios elevados.

6. Protocolo de contingencia

6.1 Escenario de falla

Un atacante que replique esta cadena (SMB anónimo → credenciales débiles → clave SSH mal permitada → escalada a root) podría comprometer completamente el servidor, alterar o eliminar datos, e instalar persistencia.

6.2 Impacto sobre la continuidad del negocio

Con acceso root, se vería comprometida la disponibilidad del servicio web y de archivos (Samba), la integridad de los datos almacenados, y la confidencialidad de cualquier información interna. El tiempo de interrupción dependería de la profundidad del compromiso (desde horas hasta días si requiere reconstrucción completa).

6.3 Plan de respuesta

- 1. Activación: Detección vía monitoreo de accesos SSH anómalos y cambios de integridad en archivos críticos.*
- 2. Contención: Aislar el servidor de la red, revocar credenciales comprometidas (jan, kay), rotar claves SSH.*
- 3. Recuperación: Restaurar desde backup verificado, aplicar parches de las vulnerabilidades identificadas antes de reconectar.*
- 4. Comunicación: Notificar a dirección de IT y, si corresponde, a usuarios afectados, según políticas internas.*
- 5. Post-mortem: Documentar la cadena de ataque completa (como en este informe) y verificar que todas las remediaciones de la sección 5 fueron aplicadas.*

6.4 RTO y RPO estimados

RTO: 4 horas — tiempo estimado para aislar el servidor, restaurar desde el último backup verificado y aplicar los parches de la sección 5 antes de reconectarlo a producción.

RPO: 24 horas — asumiendo backups diarios, es la máxima pérdida de datos tolerable si el compromiso no se detecta inmediatamente.

7. Anexos

Anexo A — Bitácora de comandos

Ver bitacora/clase_01_*.txt en el branch vera-martin.

Anexo B — Capturas de pantalla

Ver carpeta evidencias/ con subcarpetas por fase.

Anexo C — Hashes de las flags obtenidas

| `root/flag- sha 256 = 852afba51134631548962400b2970b958e1a5b3cf52c48ee1433d9930fcb2a21`

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante: ____ Martin VERA _____ Fecha: __ 08/10/2026 _____